Организационное обеспечение защиты информации

Соколов В.Е.

Организация защиты информации

- Для обнаружения таких проблем рассмотрим аппарат под названием «Окно Джохари»
- В 1955-м году два американских психолога **Джо**зеф Лифт и **Хари**нгтон Инхам разработали технику, которая позволяет людям лучше понять взаимосвязь между своими личными качествами и тем, как их воспринимают окружающие
- В соответствии с методикой, названной «Окном Джохари» у каждого человека имеются 4 зоны:
  - Открытая
  - Слепая
  - Спрятанная
  - Неизвестная

Организация защиты информации

- **Открытая зона** – это зона в которой человек знает о себе и это же знают о нём окружающие

- **Слепая зона** – это зона в которой человек о себе не знает, но о нём знают окружающие

- **Скрытая зона** – это зона где человек знает что-то о себе, но об этом не знают окружающие

- **Неизвестная зона** – это зона где человек не знает ничего о себе и другие тоже не знают о человеке

Организация защиты информации

- Эта концепция замечательно накладывается на информационную безопасность и в частности на обнаружение угроз

	Известно аналитику ИБ	Не известно аналитику ИБ
Известно другим	Открытая	Слепая
Не известно другим	Скрытая	Неизвестная

- Другие – это исследователи, хакеры, спецслужбы …

Организация защиты информации

- Открытая зона

Известно аналитику

Известно другим

Плохие файлы
Плохие IP, URL
Спам/Фишинговые Email
Сигнатуры
Уязвимости
Индикаторы компрометации

Организация защиты информации

- Для открытой зоны всегда существует множество средств защиты:
  - Межсетевые экраны
  - Антивирусы
  - Сканеры безопасности (которые ищут что-то известное)
  - и т.д.

- Которые обнаруживают 95% проблем
  - Атаки в сетевом трафике
  - Активность на узлах
  - Вирусы по сигнатурам
  - Определяют уязвимости по определённым параметрам на узлах

Организация защиты информации

- С этими решениями возникает только одна проблема уровень доверия к производителю

- Поэтому всё зависит от разработчика
  - Его могут купить
  - Он может попасть под санкции
  - Он может обанкротится
  - и т.д.

- И тогда мы остаёмся один на один с не обновляемым средством защиты

Организация защиты информации

- Если мы опираемся только на одно средство защиты, то к сожалению злоумышленники зная об этом средстве могут обойти механизмы защиты

- Так как используемые средства защиты опираются только на определённые сигнатуры

- Поэтому необходимо опираться на несколько источников информации о возможных уязвимостях

Организация защиты информации

- Слепая зона

	Неизвестно аналитику
Известно другим	Нехватка логов Разрыв в процессах Нехватка интеграции/масштабирования Нехватка корреляции из разных логов Ложные срабатывания

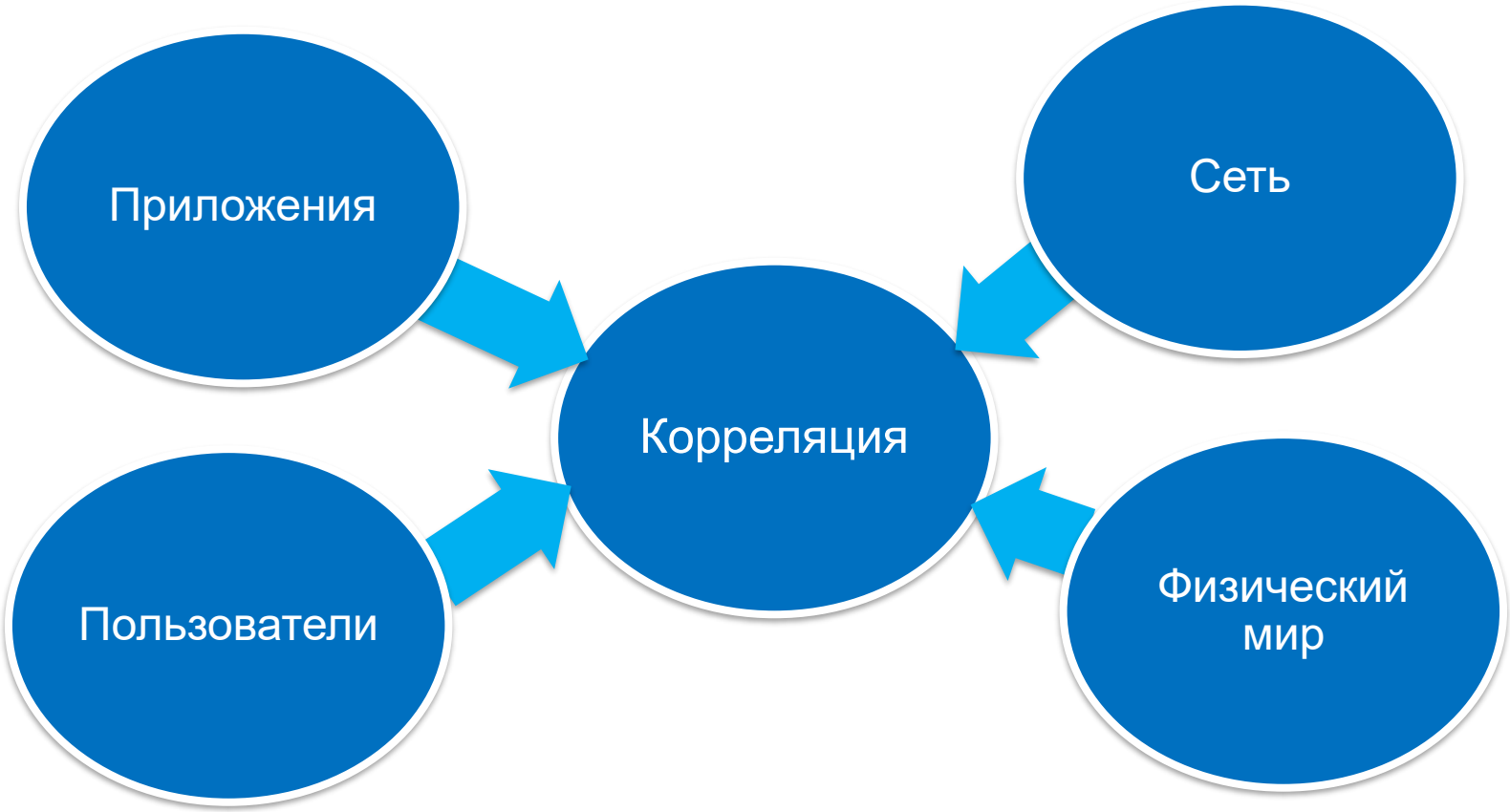
Организация защиты информации

- Для того чтобы повысить эффективность работы системы защиты необходимо увеличивать объёмы собираемых и анализируемых данных.

- Это может быть информация из
  - Логов
  - Сигналов тревоги (от антивирусов, сканеров и т.д.)
  - Контента (e-mail, файлы, web-страницы, видео и т.д.)
  - Потоков
  - Идентификационных данных (имена пользователей, сертификаты и т.д.)

Организация защиты информации

- Для слепой зоны необходима корреляция данных



Организация защиты информации

- Скрытая зона

	Известно аналитику
Не известно другим	Контекст Корреляция событий Исторический контекст Базовый профиль (эталон) Анализ данных

Организация защиты информации

- О чём знаем мы и не знают другие?

- **Активы/Сеть**
  - Сетевая топология
  - Профиль актива
    - Адрес/местоположение
    - Аппаратная платформа
    - Операционная система
    - Открытые порты/Сервисы/Протоколы
    - Клиентское и серверное ПО и его версии
    - Статус защищённости
  - Уязвимости
- **Пользователь**
  - Местоположение
  - Профиль доступа
  - Поведение
- **Файл/Данные/Процесс**
  - Движение
  - Исполнение
  - Метаданные
  - Источник
  - «Родитель»
  - Репутация
- **Безопасность**
  - Точечные события
  - Телеметрия
  - Ретроспектива

Организация защиты информации

- Откуда берётся эта информация?
- Она берётся из тех же средств защиты:
  - Межсетевые экраны
  - Антивирусы
  - Системы анализа логов
  - А ещё ОС, СУБД, …

Организация защиты информации

- На что здесь обращаем внимание:

Активность	Контекст	Телеметрия
• Системная (изменение поведения ИТ-систем или шаблонов доступа) • Объективная (шаблоны местонахождения и времени) • Бизнес	• Социальный (социальные коммуникации) • Здоровье / психология (изменение в психологии и здоровье) • HR (непростые жизненные события)	• Финансовая (непредвиденные или неожиданные траты) • Безопасность (нарушение политик ИБ) • Криминальная

Организация защиты информации

- Необходимо выбрать индикаторы:
  - Неудачные попытки входа в систему
  - Доступ к нетипичным ресурсам
  - Профиль сетевого трафика
  - Утечки данных (по объёму, типу сервиса и контенту)
  - Нетипичные методы доступа
  - Изменение привилегий
  - Нетипичные команды
  - Нетипичные поисковые запросы

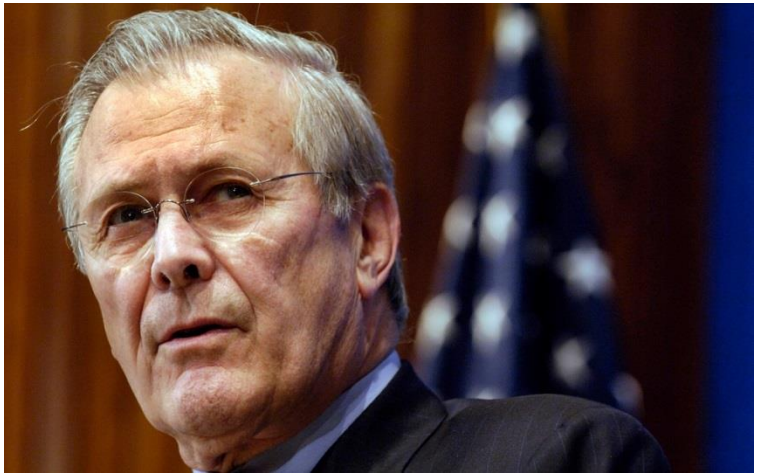
Организация защиты информации

- Примеры индикаторов
  - Негативные сообщения в социальных сетях
  - Наркотическая или алкогольная зависимость
  - Потеря близких
  - Проигрыш в казино
  - Ухудшение оценок
  - Изменение финансовых привычек (покупка дорогих вещей)
  - Нестандартные ИТ-инструменты (сканеры, снифферы и т.п.)

Организация защиты информации

- Неизвестная зона

  - *Есть известные известные – вещи, о которых мы знаем, что знаем их.*
  - *Есть также известные неизвестные – вещи, о которых мы знаем, что не знаем.*
  - *Но ещё есть неизвестные неизвестные – это вещи, о которых мы не знаем, что не знаем их*



Бывший министр обороны США
Дональд Рамсфельд

Организация защиты информации

- Неизвестная зона

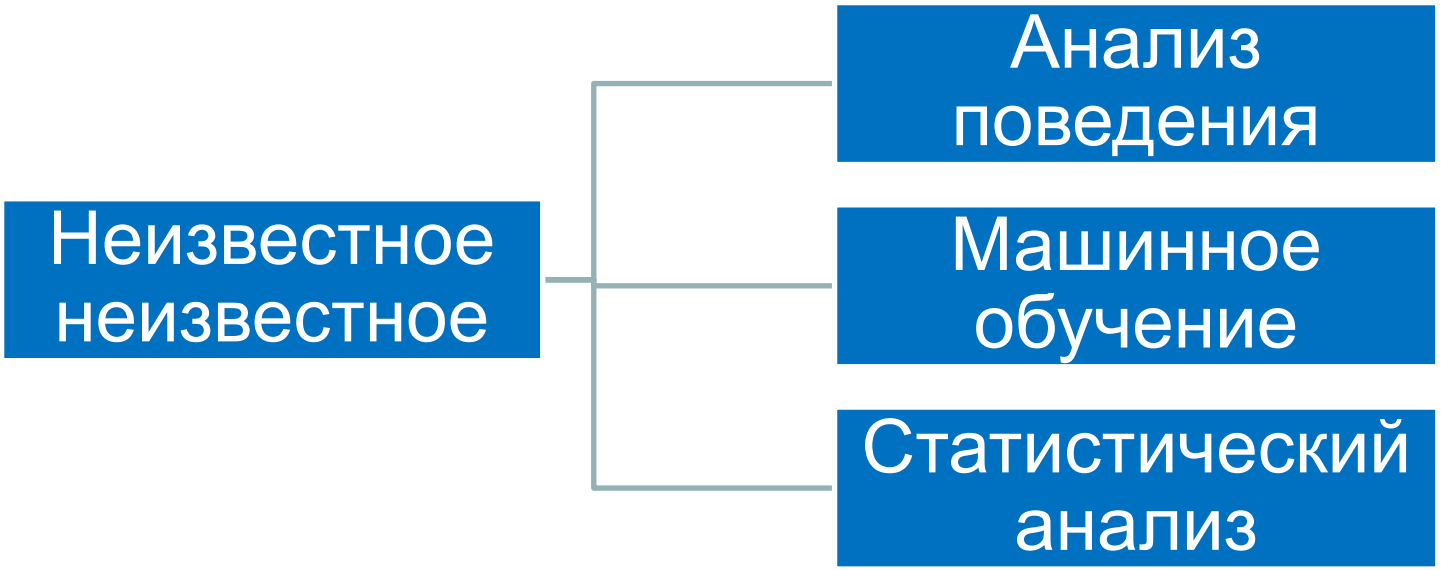
Не известно аналитику

Не известно другим

Выпадающие события
Аномальное поведение
0-Days
Ещё нет сигнатур / решающих правил

Организация защиты информации

- Обнаружение угроз в неизвестной зоне



Организация защиты информации

- Обнаружение аномалий и классификация событий

Обнаружение аномалий

- Скажи мне если произойдёт что-то необычное

Классификация

- Скажи мне когда ты увидишь нечто, похожее на это

Организация защиты информации

От телеметрии к угрозам

- Без сбора и анализа телеметрии мы никогда не получим информации об аномалиях
- Знание аномалий ещё не даёт нам знания об угрозах и вредоносной активности



Организация защиты информации

- Оставшиеся 50% бюджета направляются на поиск 5% угроз

- Решать тратить или не тратить решают сами организации

- Важно понять, что ИБ - это не **состояние**, а **процесс** (это как получение прибыли, у которого бывают взлеты и падения).

Организация защиты информации

- Полный анализ рисков включает в себя определение ценности информационных ресурсов, оценку угроз и уязвимостей, выбор адекватных контрмер, оценку их эффективности.

- В ГОСТ Р ИСО/МЭК 17799:2005 «Информационные технологии. Методы обеспечения безопасности. Практические правила управления информационной безопасностью» выделяются следующие типы ресурсов:

Организация защиты информации

- **Информация**: базы данных и файлы данных, договоры и соглашения, системная документация, руководства пользователей, планы обеспечения непрерывности бизнеса, процедуры восстановления, журналы аудита и архивная информация;

- **Программные ресурсы**: прикладное программное обеспечение, системное программное обеспечение, средства разработки и утилиты;

- **Физические ресурсы**: компьютерное оборудование, коммуникационное оборудование, переносные носители и другое оборудование;

Организация защиты информации

- **Сервисы**: вычислительные и телекоммуникационные сервисы, основные коммунальные услуги, например отопление, освещение, электроэнергия и кондиционирование;
- **Люди**, а также их квалификации, навыки и опыт;
- **Нематериальные ресурсы**, такие как репутация и имидж организации.



Организация защиты информации

- При анализе рисков, ожидаемый ущерб, в случае реализации угроз, сравнивается с затратами на меры и средства защиты, после чего принимается решение в отношении оцениваемого риска, который может быть:



Организация защиты информации

- **Снижен**, например, за счет внедрения средств и механизмов защиты, уменьшающих вероятность реализации угрозы или коэффициент разрушительности;
- **Устранен**, за счет отказа от использования подверженного угрозе ресурса;
- **Перенесен**, например, застрахован, в результате чего в случае реализации угрозы безопасности, потери будет нести страховая компания, а не владелец ИС;
- **Принят**.

Организация защиты информации

- Множество и разнообразие возможных средств защиты информации определяется, прежде всего, возможными способами воздействия на дестабилизирующие факторы или порождающие их причины.

- Причем воздействия осуществляются в направлении, способствующим:
  - **повышению** значений показателей защищенности или
  - **сохранению** прежних (ранее достигнутых) их значений.

Организация защиты информации

- Ключевыми способами обеспечения безопасности являются:

  – **Построение препятствия** (или блокирование) на пути возникновения или распространения дестабилизирующего фактора

  – **Маскирование** с целью преобразования информации, вследствие которой она становится недоступной для злоумышленников или доступ до неё существенно затрудняется, а также комплекс мероприятий по уменьшению степени распознавания самого объекта.

Организация защиты информации

- **Регламентация** как способ защиты информации заключается в разработке и реализации в процессе функционирования объекта комплекса мероприятий, создающих такие условия, при которых существенно затрудняются проявление и воздействие угроз.

- **Принуждение** - такой метод защиты, при котором пользователи и персонал системы вынуждены соблюдать правила обработки, передачи и использования защищаемой информации под угрозой материальной, административной или уголовной ответственности.

Организация защиты информации

– **Побуждение** как способ защиты информации, при котором пользователи и персонал объекта внутренне (т. е. материальными, моральными, этическими, психологическими и другими мотивами) побуждаются к соблюдению всех правил обработки информации.

– **Нападение** как применение информационного оружия при ведении информационной войны, так и непосредственное физическое уничтожение противника (при ведении боевых действий) или его средств разведки.

Организация защиты информации

- Рассмотренные способы обеспечения защиты информации реализуются с применением различных методов и средств.

- При этом различают **формальные** и **неформальные** средства.
- К **формальным** относятся такие средства, которые выполняют свои функции по защите информации формально, т. е. преимущественно без участия человека.
- К **неформальным** относятся средства, основу которых составляет целенаправленная деятельность людей.


Методы отражения угроз
1. Правовые (законодательные) - законодательные акты государства, имеющие отношение к вопросу обеспечения безопасности информации.
2. Морально-этические – это всевозможные нормы, которые сложились традиционно или складываются по мере распространения информационных технологий в АС.
3. Организационные (административные, экономические) - регламентируют процессы функционирования системы обработки данных, использование ее ресурсов, деятельности персонала
4. Физические (инженерно-технические) – устройства и сооружения, предназначенные для создания физических препятствий от проникновения и доступа нарушителей к компонентам системы
5. Технические – основаны на использовании различных электронных устройств, предназначенных для предотвращения НСД к данным.
6. Аппаратно-программные – предназначены для устранения проявления угроз, непосредственно связанных с процессом обработки и передачи информации